

Technical note - Limits of passive detection against SMB3 encryption

Project: CSDS (Cyber Security Daemon System) **Date:** June 18, 2026 **Context:** Pass-the-Hash / lateral movement detection via a passive network sensor (Zeek) **Author:** CyberCity team

1. Executive summary

While developing the Pass-the-Hash detection engine (`pth_detect.zeek`), we found that a successful `impacket-atexec` / `psexec` attack against the domain controller was **not detectable** by our passive sensor, whereas the DCSync attack (`secretsdump`) was detected perfectly.

The investigation showed that **SMB3 encryption** applied by Windows Server 2022 makes all SMB traffic invisible **after authentication**. This is a structural limit of **any** passive network detection solution (NDR, IDS, Zeek, Suricata...), not a defect specific to CSDS.

We adapted the detection strategy to rely on signals that **survive encryption** (NTLM authentication, connection metadata, lateral movement).

2. Lab context

Machine	IP	Role
CSDS	192.168.1.39	Zeek sensor (passive) + dashboard
Kali	192.168.1.47	Attacker
Ubuntu (Samba)	192.168.1.82	Linux SMB target
Windows Server 2022	192.168.1.91	Domain controller (AD)
Host	192.168.1.98	Trusted machine (whitelist)

AD domain: `CYBERCITY`.

3. Initial observation

3.1 Attack executed (Kali)

```
impacket-atexec CYBERCITY/Administrateur@192.168.1.91 whoami
```

Output on the Kali side (working attack):

```
[*] Creating task \AjDwVRNj
[*] Running task \AjDwVRNj
[*] Deleting task \AjDwVRNj
[*] Attempting to read ADMIN$\Temp\AjDwVRNj.tmp
```

The attack does create a scheduled task (pipe `atsvc`) and accesses `ADMIN$` - the full Pass-the-Hash / remote execution scenario.

3.2 Sensor side (CSDS) - partial detection

```
PTH NTLM AUTH: 192.168.1.47 -> 192.168.1.91 user=CYBERCITY\Administrateur
```

Only the **NTLM authentication** is visible. No trace of: - access to the `ADMIN$` share (tree connect), - opening of the `atsvc` pipe (create), - the scheduled-task DCE-RPC traffic.

Our initial detection (`ADMIN$` + `svcctl/atsvc`) therefore could not work.

4. Diagnostic method

To determine whether the SMB events were firing, we instrumented the generic `smb2_message` event, which fires for **every** SMB2 message, and printed the command code:

```
event smb2_message(c: connection, hdr: SMB2::Header, is_orig: bool)
{
    if ( ! is_orig ) return;
    print fmt("PTH DEBUG SMB2: %s -> %s cmd=%d",
        c$id$orig_h, c$id$resp_h, hdr$command);
}
```

SMB2 command codes expected for `atexec`:

Code	Command	Role in the attack
0	NEGOTIATE	Dialect negotiation
1	SESSION_SETUP	Authentication (NTLM)
3	TREE_CONNECT	Access to <code>IPC\$</code> / <code>ADMIN\$</code>
5	CREATE	Opening the <code>atsvc</code> pipe / file
11	IOCTL	DCE-RPC calls

Observed result

```
PTH DEBUG SMB2: 192.168.1.47 -> 192.168.1.91 cmd=0
PTH DEBUG SMB2: 192.168.1.47 -> 192.168.1.91 cmd=1
PTH DEBUG SMB2: 192.168.1.47 -> 192.168.1.91 cmd=1
... (no further messages)
```

Only `cmd=0` (NEGOTIATE) and `cmd=1` (SESSION_SETUP) are visible. Commands 3, 5 and 11 never appear.

5. Explanation: SMB3 encryption

Since SMB 3.0 (and reinforced in SMB 3.1.1), the protocol supports session encryption via AES (CCM/GCM). The sequence:

```
1. NEGOTIATE      -+ cleartext
2. SESSION_SETUP  | (NTLM/SPNEGO here - the session key is derived)
  (NTLM auth)     -+
  ----- From here, if encryption is negotiated:
3. TREE_CONNECT   -+
4. CREATE         | ENCRYPTED (SMB2_TRANSFORM_HEADER)
5. IOCTL / READ ... | -> unreadable for a passive sensor
                  -+
```

NTLM authentication happens **before** encryption is activated (it is what derives the key). That is why the sensor sees the authentication but nothing after it.

Windows Server 2022 applies this encryption (server configuration or per-share EncryptData), making ADMIN\$, IPC\$ and named pipes opaque.

6. Why DCSync remained detectable

A fair question: if SMB is encrypted, why was DCSync (secretsdump) detected perfectly (DRSUAPI BIND, RPC REQUEST)?

Because DCSync does not use SMB. The AD replication protocol (MS-DRSR) uses a **DCE-RPC over TCP** transport (ncacn_ip_tcp):

Attack	Transport	SMB encryption?	Visible (passive)?
DCSync	DCE-RPC / TCP (135 + dynamic port, drsuapi)	Not applicable	Yes
psexec / atexec / smbexec	SMB pipes (svcctl/atsvc) + ADMIN\$	Yes (encrypted)	No

DCSync goes "around" the SMB tunnel; Pass-the-Hash goes "inside" it.

7. Proof by contrast: Samba vs Windows

To definitively confirm the diagnosis, the same attack was run against a **Samba server (Linux, 192.168.1.82)**, which **does not encrypt** by default:

```
PTH NTLM AUTH: 192.168.1.47 -> 192.168.1.82 user=UBUNTUSERVER\Administrateur
ENUM TREE:     192.168.1.47 -> \\192.168.1.82\IPC$
PTH EXEC PIPE: 192.168.1.47 -> 192.168.1.82 (\svcctl)    <- visible!
RPC REQUEST:   192.168.1.47 opnum=15
```

Same attack, same tool, opposite result:

Target	SMB encryption	svcctl pipe visible?
Windows DC .91	Enabled	No
Samba Linux .82	Disabled	Yes

This contrast isolates encryption unambiguously as the sole cause.

8. Implications

1. **No passive network sensor** can inspect the contents of an encrypted SMB3 session. This holds for Zeek, Suricata, and commercial NDRs.
 2. Detecting **remote execution** (service creation, scheduled task) over encrypted SMB requires **host telemetry** (Windows logs, Sysmon, EDR on the target).
 3. Still usable passively:
 4. **NTLM authentication** (user, domain, workstation),
 5. connection **metadata** (source, destination, port, volume),
 6. **behavioral patterns** (lateral movement, beaconing).
-

9. Strategy adopted in CSDS

The `pth_detect.zeek` engine was redesigned (V2.x) around encryption-resilient signals:

Detection	Signal	Score	Block
Lateral movement	1 source -> NTLM auth to >= 2 hosts	+60	Yes
Privileged NTLM auth	admin account over NTLM (Kerberos expected)	+45	Suspicious
PtH-exec (bonus)	ADMIN\$ + svcctl/at svc if SMB is cleartext	+70	Yes

The "cleartext" path is kept: it automatically reactivates against unencrypted targets (Samba, older systems, shares without `EncryptData`).

Validation (2026-06-18): - Single-target admin NTLM auth -> +45 (suspected). OK - Lateral movement (2 hosts) -> +60 -> score 105 -> **block**. OK - Cleartext path against Samba -> `svcctl` pipe detected. OK

10. Conclusion

This investigation illustrates a key detection skill: knowing how to **distinguish a tool gap from a model limit**. Here, the lack of detection was not a bug but a cryptographic property of the protocol. The right response is not to "force" visibility, but to **shift detection toward observable signals** and to honestly document what requires another data source (host telemetry).

This approach - defense in depth, network/host complementarity - is exactly the positioning of a system like CSDS.